PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Mode opératoire d'attaque APT28

03-1170 CERT-FR - Le mode opératoire d'attaque APT28 et ses campagnes depuis 2021 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le groupe APT28 cible prioritairement les secteurs gouvernementaux, militaires, de la défense et de l'énergie en Europe et en Amérique du Nord.
2. L'attaquant recherche la discrétion en compromettant des équipements de périphérie peu surveillés comme les routeurs ou les VPN.
3. L'accès initial repose sur l'exploitation de la messagerie via l'hameçonnage, la force brute ou des vulnérabilités comme CVE-2023-23397.

Profil de l'attaque APT28

Notion	À retenir
Les cibles	Mode opératoire d'**espionnage** (Fancy Bear, Sofacy…), actif depuis **2004**, attribué par l'UE à la **Russie**. Cibles : **gouvernement**, **militaire**, **défense**, **énergie**, **médias** (Europe, Amérique du Nord) ; depuis le **24 février 2022** : Ukraine, OTAN, UE. En France depuis 2021 : ministères, collectivités, **BITD**, aérospatial, recherche, finance.
La recherche de discrétion	Compromission d'équipements de périphérie peu surveillés (**routeurs**, **passerelles**, **serveurs de messagerie**, **pare-feux**, **VPN**). Parfois **aucune porte dérobée** : accès direct aux **conversations**, **carnets d'adresses** et **identifiants**.

Mode opératoire APT28

Notion	À retenir
Reconnaissance et capacités	Hameçonnage via **comptes compromis**, force brute sur **messageries personnelles** ; jour-zéro Outlook **CVE-2023-23397** (mars 2022 à juin 2023), **Follina**, failles **Roundcube** ; outils **OSINT**, **Mimikatz**, **reGeorg** ; services gratuits (**Mocky**, **Mockbin**, **InfinityFree**). TTP **évolutives**, pas entièrement renouvelées.
Accès initial	Hameçonnage (**fausse page d'authentification**), courriels exploitant des **failles client**, ou ciblage d'**interfaces d'authentification** (identifiants valides ou force brute).
Campagnes notables	Ciblage répété de **Roundcube** (exfiltration des messageries) ; chaîne **InfinityFree** + **Mocky** → porte dérobée **HeadLace** (2023) ; voleur **OceanMap** : mots de passe des navigateurs exfiltrés via **IMAP**.

Recommandations de sécurité

Notion	À retenir
Approche globale	Apprécier les **risques** : actifs, état du système, compétences, menaces et **mesures à entretenir dans le temps**.
Messagerie	Protéger la **confidentialité**, plateforme d'**échanges sécurisés**, réduire la **surface d'attaque des webmails** et la **latéralisation depuis Exchange**, développer l'**investigation**.
Authentification et postes	Réduire les risques (**fuites de données**, **force brute**) via l'**authentification multifacteur** et sécuriser les **postes** et l'accès aux **contenus Internet** (services gratuits détournés).

Pièges et confusions

- ⚠ Confondre l'attribution de l'APT28 (Russie) avec un autre État
- ⚠ Croire que l'APT28 cherche à être bruyant plutôt que de compromettre des équipements de bordure peu supervisés pour rester discret
- ⚠ Croire que les TTP d'APT28 ont été entièrement renouvelées depuis 2021 : elles évoluent seulement.
- ⚠ Oublier que l'APT28 vise l'espionnage

Sigles et définitions

MOA	Ensemble de tactiques, techniques et procédures, d'outils et d'infrastructures caractérisant un groupe d'attaquants
APT28	Mode opératoire actif depuis au moins 2004 attribué par l'Union européenne à la Russie
TTP	Décrivent le comportement d'un attaquant à chaque étape d'une attaque
Force brute	Essaye massivement des combinaisons d'identifiants et de mots de passe
Credentials harvesting	Collecte massive d'identifiants de connexion
Mimikatz	Extrait les mots de passe ou leurs empreintes stockés en mémoire sous Windows
C4	Centre de coordination des crises cyber réunissant l'ANSSI, le COMCYBER, la DGA, la DGSE et la DGSI

Auto-test

1. Quels secteurs sont ciblés par APT28 ?
2. Quel type d'équipements est compromis pour assurer la discrétion ?
3. Citez une vulnérabilité exploitée par le groupe.
4. Comment s'appelle la porte dérobée utilisant la chaîne InfinityFree + Mocky ?
5. Quelle mesure permet de réduire les risques de fuites de données et de force brute ?

Réponses : **1.** Organisations gouvernementales, militaires, défense, énergie, médias · **2.** Équipements de bordure peu supervisés · **3.** CVE-2023-23397 · **4.** HeadLace · **5.** L'authentification multifacteur

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.